

Содержание

Записи по AppSec от VK	2
Введение в курс	2
Программа и логика курса	2
Практические задания для самостоятельной работы	3
Получение сертификата	3
Структура курса	3
Домашние задания и семинары	3
Контроли	3
Информационная безопасность в бигтехе	4
Infosec Color Wheel	4
Чем можно заниматься в ИБ	5
Безопасность приложений	5
Безопасность инфраструктуры	6
Сетевая безопасность	6
Тестирование на проникновение	6
Security Operation Center (SOC)	6
Identity and Access Management (IAM)	6
Антифрод	7
Архитектура в ИБ	7
Разработка в ИБ	7
Security Awareness	7
Bugbounty	7
Дополнительные материалы:	8

Записи по AppSec от VK

Введение в курс

Программа и логика курса

Курс состоит из:

1. 12 лек + семинаров
2. 1 промежуточный тест, 1 финальный тест и экзамен
3. 4 самостоятельных практических задания

“Курс проходит с 7 октября 2025 по 18 декабря 2025 + время на экзамен. Выдача сертификатов после...”

Программа курса:

1. Введение в информационную безопасность – лекция
2. Основы Application Security — лекция
3. Уязвимости в клиентской части веб-приложений – лекция
4. Уязвимости в клиентской части веб-приложений– семинар
5. Промежуточное тестирование
6. Уязвимости в серверной части веб-приложений – лекция
7. Уязвимости в серверной части веб-приложений: часть 2 – лекция
8. Уязвимости в серверной части веб-приложений – семинар
9. Уязвимости в мобильных приложениях – лекция
10. Уязвимости в мобильных приложениях – семинар
11. Основы безопасности инфраструктуры – лекция
12. Основы безопасности инфраструктуры: часть 2 – лекция
13. Основы безопасности инфраструктуры – семинар

Что мы получим после прохождения курса:

1. Понимание принципов информационной безопасности, ролей в информационной безопасности

и структуре ИБ в компаниях

1. Базовое понимание принципов Application Security (AppSec), роли AppSec-инженера и процесса SSDLC(Secure Software Development Lifecycle)
2. Понимание аспектов основных уязвимостей, актуальных для клиентской части Web-приложений
3. Знание об топ-10 уязвимостях OWASP и о методологии их поиска и эксплуатации
4. Знание об топ-10 уязвимостях OWASP и дополнительных возможных уязвимостях: о методологии их поиска и эксплуатации
5. Знание об уязвимостях клиентской части Android-приложений, научиться их выявлять, предотвращать

и применять методы защиты на практике

1. Знание об основных уязвимостях мобильных приложений, методах их эксплуатации и защите, включая перехват трафика, атаки через WebView, XSS, MITM, фишинг, SSL Pinning и безопасное проектирование в рамках SSDLC
2. Знание об инфраструктурной безопасности, безопасности ОС Linux, типовых угрозах в инфраструктуре, митигации и защите от них, а также сформировать знание о том, как работает IAC и как пишутся Ansible плейбуки

3. Базовые знание о Docker и Kubernetes, типовых уязвимостях в этих технологиях, мерах защиты и харденинг
-

Практические задания для самостоятельной работы

- Всего 4 практических заданий
- Выдаются все после каждой лекции для самостоятельной работы
- Разбираются задания на семинаре

“

- Вопросы по практике можно задать в чате
- Выполнять практику рекомендуем самостоятельно, без ChatGPT и помощи друзей, если действительно хотите закрепить навыки”

Получение сертификата

Разбалловка по курсу:

- 61-74 балла: 3
- 75-89 баллов: 4
- 90-100 баллов: 5

“Промежуточное тестирование — макс. 15 баллов, итоговое тестирование — макс. 15 баллов, экзамена — макс. 15 баллов, опрос — 10 баллов. Баллы можно увидеть на платформе в личном кабинете.”

Структура курса

Темы лекций:

1. Введение в информационную безопасность
 2. Введение в безопасность приложений
 3. Уязвимости в клиентской части веб-приложений
 4. Уязвимости в серверной части веб-приложений (в 2-ух частях)
 5. Уязвимости в мобильных приложениях
 6. Основы безопасности инфраструктуры (в 2-ух частях)
-

Домашние задания и семинары

- Каждую лекцию (начиная с 3-ей) преподаватель выдает лабораторные работы.

- Лабораторные работы решаются самостоятельно, затем (выборочно)

разбираются преподавателем на семинаре, там же можно задать вопросы по лабам и просто по теме лекции.

- Всего 4 семинара — клиентсайд, серверсайд, мобильные приложения, инфраструктура.
-

Контроли

- Промежуточное тестирование (примерно после 5-ой лекции)

- Экзамен

Информационная безопасность в бигтехе

Что такое ИБ?

- *Безопасность информации* — состояние защищенности информации, при котором обеспечены ее конфиденциальность, доступность и целостность. [ГОСТ Р 50922-2006, статья 2.4.5]
- *Защита информации* — деятельность, направленная на предотвращение утечки защищаемой информации, несанкционированных и непреднамеренных воздействий на защищаемую информацию. [ГОСТ Р 50922-2006, статья 2.1.1]

Триада:

- Integrity (целостность)

“Данные являются точными и полными и не могут быть изменены и уничтожены несанкционированным способом, обеспечивает достоверность информации и не допускает ее искажения”

- Confidentiality (конфиденциальность)

“Защищает данные от несанкционированного доступа, доступ к данным имеют только уполномоченные лица”

- Availability (доступность)

“Данные доступны авторизованному пользователю в любое время в необходимых объемах”

Зачем ИБ большим компаниям

- Минимизация рисков атак и утечек информации (оборотные штрафы)
- Соответствие нормативным требованиям и стандартам
- Защита пользователей
- Минимизация репутационных рисков
- Обеспечение качества разрабатываемых систем

Регламенты и стандарты

- Внутренние стандарты (политика информационной безопасности,

регламент по разработке безопасного ПО)

- Российские стандарты (ГОСТы, ФЗ, требования ФСТЭК)
- Международные стандарты (ISO, фреймворки оценки защищенности,

PCI DSS)

Infosec Color Wheel

- Red Team (main)

“Offensive Security / атакующие:

- Ищет уязвимости в приложениях, инфраструктуре и сетях
- Имитирует действия злоумышленников
- Тестируют защищенность компании (в том числе физическую)
- Проверяют осведомленность сотрудников (социальная инженерия)

”

- Blue Team (main)

“Defensive Security / защитники:

- Занимается мониторингом и реагированием на инциденты ИБ (SOC и не только)
- Расследует инциденты ИБ для понимания причин и последствий атак(форензика)
- Внедряет и настраивает инструменты защиты
- Занимается управлением уязвимостями и их устранением

”

- Yellow Team (main)

“Software coders, and Architects”

- Green Team (смежное = Blue + Yellow)

“Enhances security automation with code and design”

- Orange Team (смежное = Yellow + Red)

“Facilitates Interaction and Education”

- Purple Team (смежное = Red + Blue)

“Integrates defensive tactics with offensive results”

- White Team (центр ИБ)

“Management, Compliance, Analysts, Logistics”

“Переход между сферами наиболее удобен если они смежные, а также удобно прийти из White Team куда угодно...”

Чем можно заниматься в ИБ

Безопасность приложений

AppSec – практика защиты приложений от уязвимостей и атак.

Инженер по безопасности приложений:

- Тестирует веб-приложения на безопасность
- Внедряет и настраивает инструменты анализа приложений
- Взаимодействует с командами разработки для построения процесса безопасной разработки

- Участвует в архитектурном и feature ревью

Безопасность инфраструктуры

Безопасность инфраструктуры представляет из себя обеспечение защищенности серверов, контейнеров, оркестраторов контейнеров, IaC и прочего.

Инженер по безопасности инфраструктуры:

- Внедряет и настраивает инструменты анализа защищенности

инфраструктуры, IDS/IPS, фаерволы и т.д.

- Проводит сканирование, патчинг и харденинг операционных систем

и контейнерных сред

- Проводит ревью архитектуры и составляет требования к безопасной реализации на уровне инфраструктуры

Сетевая безопасность

Сетевая безопасность – процесс обеспечения защищенности внутренних систем компании.

Инженер по сетевой безопасности:

- Внедряет и настраивает инструменты сканирования и мониторинга

внутренних сетей, фаерволы

- Участвует в проектировании сети компании
- Обеспечивает безопасный доступ в корпоративную сеть
- Отражает и митигирует DDoS-атаки

Тестирование на проникновение

Пентест – процесс имитации действий злоумышленника с целью выявить уязвимости в системе.

Специалист по тестированию на проникновение:

- Находит уязвимости в веб-приложениях, инфраструктуре, внутренней

сети компании

- Прорабатывает сценарии эксплуатации уязвимостей с целью получить

максимальный импакт

- Вырабатывает рекомендации по устранению уязвимостей

Security Operation Center (SOC)

SOC – подразделение, отвечающее за выявление и отражение атак на компанию.

- L1: Обнаружение и первичная обработка инцидентов по плейбукам
- L2: Глубокий разбор и расследование инцидентов, реагирование

на сложные инциденты, написание плейбуков для L1

- L3: Проактивный поиск сложных угроз, threat intelligence, помощь

в расследовании отдельных инцидентов

Identity and Access Management (IAM)

IAM – процесс управления учетными данными, ролями и привилегиями к компании.

Специалист по IAM:

- Составляет, внедряет и поддерживает модель доступа к информации

и информационным системам внутри компании

- Имплементирует модели своевременной и безопасной выдачи доступов

сотрудникам

- Внедряет лучшие практики, связанные с управлением учетными

данными (MFA, SSO и т.д.)

Антифрод

Антифрод – практика выявления и предотвращения мошеннических действий.

Антифрод-аналитик:

- Занимается мониторингом действий на платформе с целью выявления фрода
- Разрабатывает модели и правила детектирования мошеннических действий
- Расследует инциденты, связанные с мошенничеством
- Подготавливает рекомендации по борьбе

Архитектура в ИБ

Архитектор ИБ отвечает за проектирование, создание и поддержку систем безопасности в организации, включая компьютерные системы и данные:

- Планирует, разрабатывает и валидирует архитектуру безопасности

проектов

- Анализирует и оценивает безопасность инфраструктуры
- Создает, внедряет и сопровождает корпоративные процедуры

и политики безопасности

Разработка в ИБ

В информационной безопасности, как и в любой сфере, необходимы разработчики с хорошим пониманием предметной области.

Разрабатывать можно множество инструментов:

- Сканеры безопасности
- Системы оркестрации других инструментов безопасности
- Системы анализа логов обнаружения инцидентов
- Решения по безопасной выдаче доступов и безопасной работы

с данными

- И многое другое

Security Awareness

Security Awareness – процесс повышения осведомленности сотрудников компании в вопросах ИБ:

- Обучение базовым принципам информационной гигиены
- Проведение тестовых фишинг-рассылок
- Обучение разработчиков базовым принципам безопасной разработки
- Сбор метрик эффективности обучения

Bugbounty

Bugbounty – программа вознаграждения белых хакеров за найденные в приложении уязвимости.

Багхантеры исследуют утвержденные в программе домены (скоуп) на предмет уязвимостей, сдают отчеты.

На стороне компании-владельца программы сотрудники ИБ проводят разбор отчетов (триаж), принимают решение о вознаграждении.

Дополнительные материалы:

- ГОСТ Серия ИСО/МЭК 27000 — Информационные технологии. Методы и средства обеспечения безопасности.
- NIST SP 800-12 Rev. 1 — An Introduction to Information Security
- Jason Andress, Foundations of Information Security: A Straightforward Introduction

